REGLAS DE ORO · CONSTITUCIÓN

16 INVARIANTES DE INGENIERÍA Y SU VERIFICACIÓN AUTOMÁTICA

A JERARQUÍA NORMATIVA

CONSTITUCIÓN → principios no negociables

CORE_SYSTEM → doctrina del copilot

ADR → decisiones con contexto

AGENTS.md → reglas operativas

CI / GUARDS → verificación automática

R-01 FAIL-CLOSED EN SEGURIDAD

Rate limit, egress guard y autorización niegan ante duda. Solo los auxiliares (breaker, caché) degradan a fail-open.

VERIFICA rate-limiter.test · egress-guard.fuzz

R-02 NINGÚN DATO SIN RLS

Toda lectura o escritura multi-tenant pasa por withRLS(userId). El id del cliente no es autorización.

VERIFICA rls.test · tests/security

R-03 SECRETOS SOLO SERVER

Keys, service_role y CRON_SECRET viven en env-secrets.ts. Nunca en bundle, logs ni respuestas.

VERIFICA guard:secrets

R-04 SALIDA EXTERNA VALIDADA

Toda petición HTTP del motor pasa por egress-guard: IP pública, protocolo permitido, redirects revalidados.

VERIFICA egress-guard.test

R-05 FUENTE ÚNICA DE TOOLS

Solo tool-registry.ts registra herramientas. Un tool nuevo no crea una segunda superficie de ejecución.

VERIFICA check:entrypoint · ADR-001

R-06 EL CLIENTE NO SABE DE IA

Componentes no conocen provider, fallback ni keys. Solo el hook y el contrato AIResponse.

VERIFICA CORE_SYSTEM §3

R-07 HUMANO ANTES DE IRREVERSIBLE

Recomendación → revisión → aprobación → ejecución → auditoría. La IA nunca ejecuta cambios destructivos.

VERIFICA CORE_SYSTEM §8

R-08 DATO EXTERNO = NO CONFIABLE

OSINT, evidencias y logs van delimitados; jamás sobrescriben instrucciones del sistema.

VERIFICA intelligence-context.test

R-09 LA APP NO DEPENDE DE LA IA

Sin key o con el pool caído, el producto sigue operativo; solo se degrada el copilot.

VERIFICA e2e-ai-router

R-10 MIGRACIONES DESDE CERO

Idempotentes, con stubs de plataforma y fail-closed: sin roles no hay verde silencioso.

VERIFICA Integration (Postgres real)

R-11 SIN EVIDENCIA NO HAY DONE

Ninguna afirmación de validación sin comando ejecutado y salida observada.

VERIFICA quality-gate · revisión

R-12 OWNER-ONLY POR DEFECTO

El acceso a datos de proyecto se deriva del ownership, no de membresías implícitas.

VERIFICA ADR-010 · migración 0052

R-13 PRESUPUESTO DE LATENCIA

120 s por route, IA ≤ 110 s, piso de 512 max_tokens en failover.

VERIFICA MODEL_TIMEOUTS · e2e

R-14 SEMÁNTICA, NO COLORES

UI solo con tokens OKLCH; WCAG 2.2 AA en ambos temas; animación respeta reduced-motion.

VERIFICA a11y.spec · design tokens

R-15 PARIDAD DE IDIOMA

Toda clave i18n existe en es y en; los prompts de IA también son bilingües.

VERIFICA guard:i18n

R-16 UN PUNTO DE ENTRADA

Una ruta, un handler; sin duplicar lógica entre camino síncrono y worker de cola.

VERIFICA check:entrypoint · review

CLÁUSULA DE BLOQUEO

Una violación de R-01 a R-08 bloquea el merge: son condiciones de seguridad, no preferencias de estilo. Las reglas R-09 a R-16 son condiciones de entrega y se verifican en el mismo pipeline. Excepción documentada únicamente vía ADR con fecha, motivo y control compensatorio.

STRATEGICAUDIT PRO — ATLAS TÉCNICO GOBIERNO DE INGENIERÍA			CAD
Invariantes no negociables del sistema			
Nº PLANO	SCAUDIT-CAD-07	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	07 / 10	FORMATO	A4 · 210×297
DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO			